

Запись об инциденте информационной безопасности

08_Инцидент_компрометация_токена.md

Раскрытие аутентификационных данных в исходном коде

Дата выявления: 16.08.2026. Выявлено при правовом анализе кодовой базы.

1. Существо инцидента

В файле `anonymizer/app.py` (строка 87 до исправления) в открытом виде находились:

- `REMOTE_URL` — адрес бэкенда, проброшенного через JupyterHub-прокси;
- `REMOTE_KEY` — **Bearer-токен пользователя JupyterHub** (32 шестнадцатеричных символа).

Назначение токена подтверждается документацией проекта: `JUPYTERHUB_GPU.md`, строка 153 — «снаружи он доступен через JupyterHub-proxy: `https://jh.interfonica.cloud/user/<id>/proxy/8000` (с Bearer-токеном, как у Ollama)»; шапка `server.py` — «clients authenticate with the JupyterHub Bearer token».

2. Объём возможного доступа

Токен пользователя JupyterHub предоставляет доступ не к отдельному эндпоинту, а к пользовательскому серверу целиком. При стандартной конфигурации это:

Что доступно	Последствие
Пользовательский сервер Jupyter	Выполнение произвольного кода на GPU-хосте от имени владельца токена
Домашний каталог пользователя	Чтение и запись всех файлов, включая <code>~/anon/.env</code>
<code>/user/<id>/proxy/8000</code>	Полный доступ к бэкенду анонимайзера. Собственной аутентификации у бэкенда нет — данный токен был единственным средством защиты
<code>/user/<id>/proxy/<порт Ollama></code>	Доступ к локальному инференсу

Транзитивная компрометация. Через доступ к домашнему каталогу раскрывается файл `.env`, содержащий `ANONYMIZER_LLM_API_KEY` — ключ доступа к внешнему инференс-шлюзу. Следовательно, раскрытие токена JupyterHub влечёт возможную компрометацию и ключа к шлюзу, несмотря на то, что последний хранился корректно (отдельный файл, права 600, не передаётся аргументами командной строки).

3. Каналы возможной утечки

- Передача исходного кода третьим лицам (аудит, потенциальный заказчик, подрядчики).
- Размещение репозитория в системах контроля версий, в том числе во внутренних.
- Резервные копии и архивы каталога проекта.

- История изменений — **даже после удаления из текущей версии значение остаётся в истории**, если каталог находился под контролем версий.

4. Принятые меры

№	Мера	Статус
4.1	Значения вынесены в переменные окружения ANONYMIZER_BACKEND_URL и ANONYMIZER_BACKEND_KEY; при отсутствии адреса приложение завершается с сообщением	☒ выполнено 16.08.2026
4.2	Отзыв токена JupyterHub и выпуск нового	☐ срочно
4.3	Ротация ANONYMIZER_LLM_API_KEY как потенциально доступного через п. 4.2	☐ срочно
4.4	Анализ журналов JupyterHub и шлюза на предмет обращений, не совершавшихся правообладателем	☐
4.5	Проверка истории системы контроля версий и резервных копий на наличие значения	☐
4.6	Введение автоматической проверки на секреты в коде (например, gitleaks, detect-secrets) в конвейер сборки	☐
4.7	Введение аутентификации входящих запросов на бэкенде — чтобы токен внешнего прокси перестал быть единственной защитой	☐

Порядок ротации имеет значение: сначала токен JupyterHub (он открывает доступ ко второму ключу), затем ключ шлюза.

5. Правовая квалификация

[ЗАКОН] Часть 3.1 статьи 21 Федерального закона от 27.07.2006 № 152-ФЗ обязывает оператора уведомить Роскомнадзор о факте **неправомерной или случайной передачи (предоставления, распространения, доступа) персональных данных**, повлёкшей нарушение прав субъектов: в течение 24 часов — первичное уведомление, в течение 72 часов — результаты внутреннего расследования.

Раскрытие аутентификационных данных само по себе передачей персональных данных не является. Обязанность уведомления возникает, только если будет установлено, что вследствие раскрытия произошёл неправомерный доступ к персональным данным.

Что необходимо установить для вывода (заполнить по результатам п. 4.4 и 4.5):

- Обработывались ли через данный контур персональные данные **реальных субъектов**, а не тестовые данные из каталога test_samples/: **да / нет** → _____
- Имеются ли в журналах обращения, не совершавшиеся правообладателем: **да / нет** → _____
- Передавался ли исходный код третьим лицам в период наличия токена в файле: **да / нет / кому** → _____
- Период нахождения значения в кодовой базе: с «» _____ по 16.08.2026

[РЕКОМЕНДАЦИЯ] Если по всем трём пунктам ответ отрицательный — уведомление Роскомнадзора не требуется, настоящая запись сохраняется как подтверждение проведённого расследования. Если хотя бы по одному положительный — немедленно инициировать процедуру по статье 21.

Настоящая запись составлена и сохраняется независимо от вывода об уведомлении. Наличие оформленной записи об инциденте и документированного расследования — самостоятельный аргумент добросовестности при проверке регулятора и при вендорском аудите; отсутствие такой записи при выявленном факте — отягчающее обстоятельство.

6. Ответственный и подписи

Выявлено: ____ Дата: 16.08.2026

Расследование завершено: ____ Дата: «» ____ 2026 г.

Вывод об уведомлении Роскомнадзора: **требуется / не требуется** — обоснование: _____